

CyberShield

Vulnerability Assessment & Exposure Management

Security Engineer Operations Guide

A practical operator's manual for running authorized security assessments, triaging findings, prioritizing risk, and executing the remediation workflow.

Version 0.1 · September 05, 2026

About this guide

This guide walks a security engineer through day-to-day use of CyberShield: starting authorized scans, discovering assets, reviewing normalized findings, using the AI Security Analyst, prioritizing and remediating vulnerabilities, handling false positives, generating reports, and maintaining audit visibility. The platform is **defensive only** — it will not exploit, deny service, or disrupt systems.

Authorized use only. Only assess assets you own or hold explicit written authorization to test. CyberShield's active scanners are sandboxed with scope, rate and timeout controls and cannot perform destructive actions.

Contents

1. Getting started	Signing in, roles, navigation
2. Scan safety & scope	The mandatory safety policy and controls
3. Domain / Web application scans	Targets, discovery, approval, profiles
4. Infrastructure / network scans	Asset types, CIDR, input methods
5. Reading findings	Severity, CVSS, risk score, evidence, standards
6. AI Security Analyst	Finding analysis and risk predictions
7. Prioritization	Top 10 things to fix now
8. Remediation workflow	Levels, approval, execute, verify, close
9. False positives & accepted risk	Exceptions with evidence and expiry
10. Reports	Executive, technical, compliance exports
11. Security Assistant chat	Ask about your data
12. Scheduling & integrations	Recurring scans and SIEM/SOC
13. Audit & SLA	Logs, hash chain, SLA dashboard
14. Troubleshooting	Common issues

1. Getting started

Open the CyberShield URL (e.g. `http://localhost:5173`) and sign in with your organization credentials. Your role determines what you can see and do.

Signing in

- Enter your email and password. Provide the 6-digit MFA code when prompted (if MFA is enabled).
- On success you land on the Executive Dashboard.
- The **user menu** (top-right) shows your profile and a Sign out option.

Roles & permissions

Role	Typical responsibilities
Security Analyst	Run scans, assess findings, manage vulnerability lifecycle, create exclusions
SOC Analyst	Monitor findings and incidents; read dashboards
Network / System Admin	Assess and remediate network devices and servers
App Security Analyst	Assess web applications, APIs and compliance
Remediation Engineer	Execute approved remediation and verify
CISO	Full visibility, risk, reports, approvals
Auditor	Read-only audit/report access
Management	Executive dashboards and reports only

Navigation

Menu	Purpose
Dashboard	Executive posture, top assets, KEV exposure, priorities
Assets	Central asset inventory and risk
Vulnerabilities	All findings with filters and lifecycle
Scan Center	Start domain/web or infrastructure scans, view history
Remediation	Approval workflow and execution status
Reports	Generate and download reports
Security Advisor	Ask questions grounded on your data

2. Scan safety & scope

Mandatory Safety Policy. Before any active scan you must confirm: *“This scan must only be performed against assets that you own or are explicitly authorized to assess.”* The platform will refuse to start a scan without this confirmation and an approved scope.

Every scan carries these configurable safety controls:

- **Scope** — authorized targets plus excluded IPs / domains; anything outside scope is blocked.
- **Profile** — Passive (no intrusive requests), Safe (low-impact), Standard (broader), Enterprise (strict rate limiting + maintenance windows).
- **Rate limit** — max requests per second (hard cap enforced).

- **Timeout** — per-request timeout.
- **Concurrency** — max parallel checks per scan (capped by platform).
- **Cancel** — emergency stop at any time.

The platform will not perform exploitation, brute force, credential theft, denial-of-service or malware actions. Active scanning only sends safe, authorized inspection requests.

3. Domain / Web application scans

Use the **Domain / Web Application Security** scanner to assess domains, URLs, IPs, web applications and API endpoints.

Step-by-step

- Open **Scan Center** and switch the mode to **Domain / Web Application Security**.
- Enter a target, e.g. `example.com`, `https://example.com/login`, or an IP.
- Optionally choose a **scan profile** (Safe is the default).
- Click **Discover subdomains** to enumerate associated subdomains passively (certificate transparency + common names).
- Review discovered subdomains — the platform marks each as **discovered / confirmed / responsive / unresponsive**, and only in-scope assets enter scanning.
- Confirm the **safety policy** and scope, then click **Start scan**.

The scan runs **asynchronously**; you can monitor its **progress** in Scan Center and stop it with **Cancel** at any time. When complete, findings appear under **Vulnerabilities**.

What the web/domain scanner checks

Area	Examples
Web security headers	CSP, HSTS (Strict-Transport-Security), X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy
TLS / certificates	Weak protocols, weak ciphers, expired or expiring certificates
Cookies / sessions	HttpOnly, Secure, SameSite flags
App configuration	CORS misconfiguration, CSRF protection gaps, Basic auth, exposed docs
Content / disclosure	Directory listing, technology fingerprint, debug/stack traces, sensitive files
DNS security	SPF, DMARC, DKIM, DNSSEC, MX, CAA, security.txt

4. Infrastructure / network scans

Use the **Infrastructure / Endpoint / Network Security** scanner to assess servers, workstations, network devices, databases, VMs, containers, storage and IoT assets.

Asset types: Server, Workstation, Router, Switch, Firewall, Wireless Controller, Access Point, Network Appliance, Database Server, Application Server, Virtual Machine, Container Host, Storage Device, IoT Device, Other.

Input methods

- IP address — e.g. `192.168.10.10`
- Hostname / FQDN
- CIDR network range — e.g. `192.168.10.0/24`
- Asset inventory, CSV import and API integration (see Administration).

CIDR authorization. Network ranges are bounded (max 256 hosts) and require strict authorization and scope controls. Sweeping large ranges is intentionally limited to protect production.

The scanner checks open/exposed services (banner + service fingerprint), weak protocols, outdated/end-of-life software, exposed management interfaces, and ports like Telnet, FTP, RDP, Redis, MongoDB — with non-intrusive, bounded requests.

5. Reading findings

Every finding is a fully normalized vulnerability record. Open **Vulnerabilities** and use the filters to narrow by severity, status, asset, CVE, CWE, CISA KEV, or search. Click any row to open the **Finding Detail** page.

Fields you will see

Field	Meaning
Finding number	Unique ID, e.g. VUL-000001
Severity	Critical / High / Medium / Low (from CVSS + context)
CVSS	0–10 base score and vector
CVE / CWE	Standard identifiers when mapped
Evidence	The safe technical observation that justifies the finding
Risk score	0–100 composite (see §: risk model)
Risk band	Critical (90–100) / High (70–89) / Medium (40–69) / Low (1–39)
KEV	Whether it is in the CISA Known Exploited Vulnerabilities catalog
Asset	Affected asset name, IP and criticality
Status	Open, Investigating, Remediation Planned, In Progress, Resolved, Verified, Closed, etc.
Age / SLA	Days since first detected and the SLA due date

Standards mapping — the finding maps (where defensible) to OWASP Top 10, OWASP ASVS/WSTG, CWE, NIST CSF, CIS Controls, ISO 27001. Mappings are evidence-based and never invented.

6. AI Security Analyst

On the Finding Detail page, the **AI Security Analyst** panel provides:

- **Why it matters** — a plain-language explanation of the risk.
- **Potential impact** — confidentiality, integrity, availability, compliance, business.
- **Predicted risk** — likely Critical/High/Medium/Low based on threat intel, exposure, age, asset criticality, exploit availability.
- **Confidence** — an indication of certainty.

AI output is clearly labelled **AI-generated risk assessment**. It is advisory and must not be treated as confirmed fact. Always corroborate against the evidence and your own triage.

7. Prioritization — top things to fix now

The **Dashboard** → **Top priorities — fix now** panel ranks the highest-impact work using risk score plus weighted factors: actively-exploited (KEV), internet-facing, critical/high-value assets, and age. Use it to direct effort.

Ranking signal	Why it ranks high
CISA KEV	The vulnerability is known to be actively exploited
Internet-facing	Remotely reachable — highest exposure
Critical/high asset	Impact on a business-critical system
High risk score	Composite of CVSS, exposure, age, criticality
Long overdue	Aging past the remediation SLA

8. Remediation workflow

Workflow: **Finding** → **Recommendation** → **Risk Review** → **Approval** → **Execution** → **Verification** → **Closure**. Create a Remediation plan from a finding (or let the platform generate one), then walk it through the workflow under **Remediation**.

Safe automation levels

Level	Automation	Examples
L1 — Safe Automatic	Yes (reversible)	Create ticket, notify owner, update status, propose config/patch, collect verification data
L2 — Approval Required	After approval	Disable a service, change firewall rule, apply baseline, change auth, restart a service
L3 — Manual	Never auto-executed	OS/firmware upgrades, database or production changes, anything that may interrupt business

Each remediation records the requester, approver, timestamps, target asset, proposed and previous configuration, backup status, execution status, verification result, rollback option and an audit log.

Approving and executing

- Submit a plan for approval. The approver (e.g. CISO) approves or rejects with a comment.
- For L2, execute after approval. The platform tracks execution; a privileged admin performs the actual system change.
- Verify by **re-running** the corresponding scanner/check on the asset — if the finding no longer appears, mark Verified, then Closed.
- Roll back if the change is undesirable or causes an outage.

For Level 3 changes, a privileged engineer performs the change manually; the platform records it only after verification. The platform never remotely mutates production systems.

9. False positives & accepted risk

On a Finding Detail page, you can mark an exception:

- **False Positive** — the finding is not genuine. Provide a reason and evidence.
- **Accepted Risk** — the risk is consciously accepted. Provide a reason, owner and expiry.
- **Compensating Control** — a control mitigates the risk. Describe the control.

Exceptions require an **analyst**, an **approver**, an **expiration date** and **evidence**. Approved exceptions suppress the finding and **auto-expire**, forcing re-review.

10. Reports

Generate reports under **Reports**. Choose the type and format, then Download.

Type	Audience	Content
Executive	CISO / management	Posture, risk score, critical findings, business impact, trends, recommended priorities
Technical	Admins / SOC / engineering	Findings, evidence, CVEs, CVSS, affected assets, remediation, verification steps
Compliance	Auditors / compliance	Defensible mappings to OWASP, NIST CSF, CIS Controls, ISO 27001

Available formats: **PDF, HTML, CSV, JSON, Excel (XLSX)**.

11. Security Assistant chat

The **Security Advisor** answers questions **using your actual scan data**. Try questions such as: “What should we fix first?”, “Which vulnerabilities are internet-facing?”, “Which are actively exploited?”, “Which are overdue?”, or “Explain this to a non-technical manager.”

The advisor is grounded on platform data and will not invent CVEs, assets or remediation. It clearly distinguishes observed facts, scanner results, external intelligence, AI inference and recommendations.

12. Scheduling & integrations

Scheduled scans — create recurring scans (one-time, daily, weekly, monthly, custom) from the scheduler. Schedules only run within authorized scope and use the same safety controls.

SIEM / SOC integration — register connectors (Wazuh, Splunk, Sentinel, Elastic, syslog, webhook, API) so security events are forwarded, including: scan started, scan completed, critical vulnerability detected, new internet-facing asset, vulnerability status changed, remediation executed/failed.

13. Audit & SLA

Audit logs record actor, action, target, source IP, timestamp, result and previous/new state. The log is tamper-evident via a **hash chain** — you can verify chain integrity in the Admin area. Audit access is permission-gated.

SLA tracking shows Critical/High/Medium SLA breaches, upcoming SLAs, average remediation time, mean time to remediate and reopened vulnerabilities. Default SLAs: Critical 7d, High 15d, Medium 30d, Low 60–90d (configurable).

14. Troubleshooting

Problem	Likely cause / resolution
Scan won't start / safety error	You must confirm safety policy + scope; ensure target is in scope and not excluded
Scan stuck at 0%	Target may be unreachable; check DNS/host. Cancel and retry with a different profile
No findings	Target may be hardened or not HTTP; results may open wider ports or a different target
Report has no data	Ensure findings/assets exist; broaden the report scope filters
Advisor not answering	AI provider may be off (mocked fallback is used); check AI configuration
Login rejected	Confirm credentials and MFA code; check your account is active

Recommendation — Always verify a finding before acting, prioritize internet-facing and KEV items first, and track remediation against SLA. Confirm AI-generated guidance against evidence.